5-Minute Capstone Demo Script

Week 12 · Care Access Navigator · HealthLine Regional Medical Center (HRMC)

Storyboard from the 12-week plan (section 14) with the exact screens, commands and numbers

Time	Segment	Show	Say	Key message
0:00-0:30	**Problem**	Deck slides 1-3	HRMC must keep ePHI and card data to the right people. Five access problems: too much access, movers keep old access, access that never ends, leavers who can still sign in, and no proof.	*Healthcare access must be secure and governed.*
0:30-1:30	**IAM**	Keycloak admin console (Groups → Billing → Role mapping) then Terminal	Show the seven job-function groups. Run the app check: a clinician gets the EHR but is denied Billing; a billing user gets an MFA prompt. Mention the mover and leaver results from TC-03 and TC-04.	*Least privilege is enforced by identity governance.*
1:30-2:30	**Incident**	Terminal, then deck slide 9	Run the password-guessing test: the account locks after 10 failures and CAN-ID-001 fires. Slide 9: leaver Jeevan Smith tries to come back (IR1-2026-001). Main case IR1-2026-002: Wazuh rule 100221 fired 1.3 s after Tara Jones read a patient record after her move to Billing; egress was blocked 49 s after the alert.	*The analyst detects and investigates abnormal activity.*
2:30-3:45	**GRC**	CISO Assistant: risk R02, control IA-01, HIPAA audit, finding CA-01, exception EX-02	R02 (leaver keeps access) stays High: the scripted leaver works, Entra-triggered disable is not built yet. Finding F-01 (no MFA) became corrective action CA-01, fixed and verified with before/after evidence. Control IA-01 maps to HIPAA 164.312(d) and CSF PR.AA-03 with evidence EV-13 and EV-17 attached. Exception EX-02 (log retention): compensating controls and an expiry date.	*IAM findings become measurable governance and risk actions.*
3:45-4:30	**Dashboard**	CISO Assistant Analytics, then the risk matrix and the HIPAA audit donut	25 HIPAA access requirements assessed: 17 compliant, 7 partially compliant, 1 non-compliant (log retention). Control test pass rate 57.1% → 85.7%. Open items are visible with owners and dates: OTP enrolment (CA-13) and vendor end date (CA-08); the access review was signed off on 2026-11-09 (CA-05).	*Security posture is communicated to management.*

Time	Segment	Show	Say	Key message
4:30-5:00	**Outcome**	Deck closing slide	10 of 10 end-to-end tests passed; the one failure exposed a real detection bug that was fixed and retested. One lesson: configuration that exists is not configuration that works; test the negative path.	*The project demonstrates an end-to-end analyst workflow.*

Before the demo (10 minutes)

Terminal set-up (keeps demo output out of the evidence folders)

```
cd ~/Desktop/dae_6mon_coh2_AC/Care_Access_Navigator
docker start care-access-postgres care-access-keycloak     # wait ~20 s, then open http://localhost:8080
(cd ../ciso-assistant-community && docker compose up -d)   # CISO Assistant: wait for healthy,
    https://localhost:8443
set -a; . 03_IAM_Lab/01_Keycloak/01_Config/.env; set +a
export KC_ADMIN=$KC_ADMIN_USERNAME KC_ADMIN_PW=$KC_ADMIN_PASSWORD CAN_EVIDENCE=/tmp/can-demo
cd 10_Scripts/02_IAM_Automation
```

- Browser tabs: Keycloak admin console (realm care-access-navigator, Groups), the deck, CISO Assistant (Analytics; risk assessment CAN-RA-001; HIPAA audit; findings assessment CAN-FA-001).
- Font size up in Terminal (Cmd +) so the room can read the results.
- Wait at least 10 minutes after any rehearsal lockout so CAN-ID-001 raises a fresh alert.

Live commands

Expected: LOGGED_IN / DENIED; MFA_REQUIRED; PASS (locked after 10 failures); a new CAN-ID-001 High line

```
# IAM (0:30): clinician allowed in the EHR, denied in Billing; billing user must pass MFA
python3 can_iam.py verify --username test.clinician2 --password "$CAN_TEST_PW" --clients ehr-simulator
    billing-app
python3 can_iam.py verify --username test.billing2  --password "$CAN_TEST_PW" --clients billing-app

# Incident (1:30): password guessing locks the account, then the detection fires
python3 can_iam.py verify --username test.billing2 --password "$CAN_TEST_PW" --clients billing-app \
        --lockout-user test.vendor1 --unlock
python3 can_iam.py detect && grep "CAN-ID-001" /tmp/can-demo/identity_detections.csv | tail -1
```

If something fails on the day

Problem	Fallback
Keycloak not up	Show EV-13 results in the Week 5 PDF, section 2 (same before/after table)
Lockout already active	Run the unlock: the --unlock flag clears it; or show TC-05 in the end-to-end report
CISO Assistant not up	Show the EV-16 dashboard screenshots and the CAN_DOC_CISO_* PDFs in 07_GRC
Over time	Skip the CISO Assistant tour; say the one-line F-01 → CA-01 story